

Security+ 1.2 · AAA (Authentication, Authorization, Accounting)

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · Aula 1.2 — AAA (Authentication, Authorization, Accounting) (9:03) · [Video no YouTube ↗](#)

Resumo da Aula: AAA: Authentication (prova quem é), Authorization (o que pode fazer), Accounting (registra o que fez). 802.1X usa RADIUS pra AAA de rede — quem conecta o cabo precisa se autenticar antes de ter acesso.

Highlights que a prova cobra

- 'Prove quem és, define o que podes, regista o que fez'
- 802.1X: acesso físico à rede precisa de login — sem isso, qualquer dispositivo entra
- RADIUS = o backend central de AAA

Dicas de prova & Cenários Típicos

- A prova menciona: 'network access control requires users to authenticate' = 802.1X + RADIUS
- Accounting = LOG de acesso (quem entrou quando) — não é accounting financeiro

Cenário clássico de exame: Cenário típico: 'empresa precisa controlar qual dispositivo e usuário acessa o switch' → 802.1X com RADIUS.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Seção 1.2)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (AAA (Authentication, Authorization, Accounting)) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Criptografia Simétrica (AES-256, ChaCha20):** Usa uma única chave idêntica para cifrar e decifrar. Excelente para confidencialidade de grandes volumes (BitLocker, banco de dados, túneis VPN). **Atenção de prova:** cifras simétricas NÃO oferecem não-repúdio quando a chave é compartilhada.
- **Criptografia Assimétrica (RSA, ECC, Ed25519):** Usa par de chaves matemáticas: a Chave Pública é distribuída livremente; a Chave Privada é mantida em segredo absoluto pelo titular. Assinar o hash com a chave privada garante **Não-repúdio e Autenticidade**. Cifrar com a chave pública do destinatário garante **Confidencialidade**.
- **Hashing (SHA-256, SHA-3) vs. HMAC:** Hash puro é função matemática unidirecional sem chave, garantindo apenas integridade (qualquer um pode recalculá-lo de um dado adulterado). O HMAC combina hash com chave simétrica secreta, provendo integridade e autenticação mútua entre sistemas conhecidos.
- **TSA (Time Stamping Authority - RFC 3161) e LTV:** Entidade confiável que assina o hash com data/hora auditada, provando o momento exato em que o documento existiu e garantindo validação de longo prazo (LTV) mesmo após a expiração de certificados.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Hash puro NÃO fornece não-repúdio.
- AES com chave compartilhada destrói o não-repúdio.
- Políticas em papel e termos de adesão são controles puramente administrativos; não bloqueiam ataques em tempo de execução.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. Um funcionário aproxima seu crachá com chip RFID e digita seu PIN em uma catraca de acesso. Em seguida, a catraca verifica se o funcionário tem permissão para entrar na sala do servidor naquele horário. Finalmente, registra no banco de dados a data, hora e ID do evento. Quais pilares do modelo AAA foram exercidos, respectivamente?

- A)** Accounting, Authorization, Authentication
- B)** Authentication, Authorization, Accounting
- C)** Authorization, Accounting, Authentication
- D)** Authentication, Accounting, Auditing

2. Um administrador de redes precisa implementar o padrão 802.1X para autenticar computadores antes que eles recebam tráfego na rede local corporativa. Qual protocolo é o padrão de mercado para atuar como o servidor AAA central nessa topologia?

- A)** RADIUS (Remote Authentication Dial-In User Service)
- B)** SNMPv3
- C)** DNSSEC
- D)** NTP

3. Qual é a diferença fundamental entre AUTENTICAÇÃO e AUTORIZAÇÃO no modelo AAA?

- A)** Autenticação verifica a identidade ('quem é você'); Autorização define privilégios e acessos ('o que você pode fazer')
- B)** Autenticação gera relatórios contábeis; Autorização cria contas de rede
- C)** Autenticação só funciona em nuvem; Autorização é exclusiva de redes locais
- D)** Não há diferença técnica, são termos intercambiáveis

4. Durante uma auditoria forense após um vazamento interno, a equipe de segurança descobre que as alterações em um arquivo confidencial não foram registradas e não há histórico de quem acessou a pasta. Qual pilar do AAA falhou nessa infraestrutura?

- A)** Accounting (Auditoria / Contabilidade de logs)
- B)** Authentication
- C)** Availability
- D)** Authorization

5. Um engenheiro de redes precisa escolher entre RADIUS e TACACS+ para administração de roteadores e switches corporativos. Qual característica torna o TACACS+ superior para controle de comandos em equipamentos de rede?

- A)** O TACACS+ separa autenticação e autorização por completo e criptografa todo o pacote TCP (porta 49)
- B)** O TACACS+ não exige senhas nem certificados
- C)** O RADIUS criptografa o pacote inteiro enquanto o TACACS+ não criptografa nada
- D)** O RADIUS usa TCP garantido enquanto TACACS+ usa UDP sem confirmação

6. Uma empresa adota autenticação multifator (MFA) obrigatória para VPN. Um usuário informa login/senha e recebe um código push no smartphone. Qual pilar do AAA foi concluído com sucesso ao validar esses fatores?

- A)** Authentication
- B)** Accounting
- C)** Federation
- D)** Authorization

7. Um estagiário de TI consegue autenticar normalmente no domínio Active Directory, mas ao tentar abrir o compartilhamento da folha de pagamento no servidor de arquivos, recebe a mensagem 'Acesso Negado'. O que isso demonstra?

- A)** A Autenticação foi bem-sucedida, mas a Autorização foi negada pela política de privilégios
- B)** O modelo AAA foi corrompido e o servidor caiu
- C)** A auditoria de Accounting bloqueou o usuário por inatividade
- D)** O usuário precisa trocar sua chave assimétrica

8. Em uma arquitetura de rede sem fio corporativa (WPA3-Enterprise), qual papel o Access Point (AP) Wi-Fi desempenha na comunicação AAA?

- A)** Atua como Autenticador (Network Access Server - NAS), intermediando os pacotes entre o cliente e o servidor RADIUS
- B)** Atua como o próprio servidor de banco de dados de senhas
- C)** Atua como autoridade certificadora raiz offline
- D)** Desempenha apenas o papel de Accounting sem tocar na autenticação

9. Para evitar que um atacante que comprometeu o servidor apague os logs de Accounting que registram suas atividades maliciosas, qual medida é recomendada pelas melhores práticas da CompTIA?

- A)** Encaminhamento de logs em tempo real para um servidor SIEM externo centralizado com regras de retenção WORM
- B)** Armazenamento dos logs apenas na memória RAM volátil
- C)** Exclusão automática de logs a cada 24 horas
- D)** Desativação de logs em contas com privilégio de administrador

10. Um sistema web corporativo utiliza SAML 2.0 para permitir que funcionários acessem ferramentas em nuvem (SaaS) usando sua credencial única de rede. Qual é o papel do Active Directory Federated Services (ADFS) nesse fluxo AAA?

- A)** Provedor de Identidade (Identity Provider - IdP), responsável por autenticar o usuário e emitir o token de asserção
- B)** Service Provider (SP), responsável apenas por hospedar o e-mail
- C)** Servidor de proxy reverso sem função de segurança
- D)** Firewall de aplicação web (WAF)

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) B — Authentication, Authorization, Accounting.

✓ **Por que está certa:** Crachá + PIN comprovam quem ele é (Authentication); checar permissão e horário é Authorization; registrar a entrada com timestamp no log é Accounting.

✗ **Por que as outras estão erradas:**

- *Accounting, Authorization, Authentication:* Inverte ou confunde a sequência estrita do modelo AAA (primeiro autentica para provar quem é, depois autoriza o acesso aos recursos, e por fim registra as ações em log de accounting).
- *Authorization, Accounting, Authentication:* Inverte ou confunde a sequência estrita do modelo AAA (primeiro autentica para provar quem é, depois autoriza o acesso aos recursos, e por fim registra as ações em log de accounting).
- *Authentication, Accounting, Auditing:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) A — RADIUS (Remote Authentication Dial-In User Service).

✓ **Por que está certa:** RADIUS (ou TACACS+) é o serviço backend AAA padrão integrado com 802.1X para autenticar dispositivos e usuários antes de liberar portas de switches e redes Wi-Fi.

✗ **Por que as outras estão erradas:**

- *SNMPv3:* É um protocolo de infraestrutura com finalidade diversa (gerenciamento de rede, integridade de DNS ou sincronismo temporal), não atuando como servidor de autenticação centralizada.
- *DNSSEC:* É um protocolo de infraestrutura com finalidade diversa (gerenciamento de rede, integridade de DNS ou sincronismo temporal), não atuando como servidor de autenticação centralizada.
- *NTP:* É um protocolo de infraestrutura com finalidade diversa (gerenciamento de rede, integridade de DNS ou sincronismo temporal), não atuando como servidor de autenticação centralizada.

3) A — Autenticação verifica a identidade ('quem é você'); Autorização define privilégios e acessos ('o que você pode fazer').

✓ **Por que está certa:** Autenticação valida credenciais para confirmar identidade. Autorização aplica as políticas de permissão que determinam quais recursos o usuário autenticado pode acessar.

✗ **Por que as outras estão erradas:**

- *Autenticação gera relatórios contábeis; Autorização cria contas de rede:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Autenticação só funciona em nuvem; Autorização é exclusiva de redes locais:* Cifra legada com tamanho de chave/bloco insuficiente e vulnerável a quebras práticas modernas (como Sweet32 e ataques de fluência).
- *Não há diferença técnica, são termos intercambiáveis:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

4) A — Accounting (Auditoria / Contabilidade de logs).

✓ **Por que está certa:** Accounting é a responsabilidade de monitorar, rastrear e registrar todas as ações e sessões dos usuários para propósitos de auditoria e conformidade.

✗ Por que as outras estão erradas:

- *Authentication*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Availability*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Authorization*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

5) A — O TACACS+ separa autenticação e autorização por completo e criptografa todo o pacote TCP (porta 49).

✓ **Por que está certa:** O TACACS+ utiliza TCP 49, cifra todo o corpo da mensagem e separa estritamente os processos de autenticação e autorização, permitindo granularidade comando por comando.

✗ Por que as outras estão erradas:

- *O TACACS+ não exige senhas nem certificados*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *O RADIUS criptografa o pacote inteiro enquanto o TACACS+ não criptografa nada*: O RADIUS criptografa apenas o campo de senha; os cabeçalhos e demais atributos trafegam em texto claro (o TACACS+ é que cifra o payload inteiro).
- *O RADIUS usa TCP garantido enquanto TACACS+ usa UDP sem confirmação*: O TACACS+ utiliza exclusivamente a porta TCP 49 para transporte confiável, enquanto o RADIUS é que utiliza portas UDP (1812/1813).

6) A — Authentication.

✓ **Por que está certa:** MFA é um mecanismo exclusivo do pilar de Autenticação (validação de identidade por múltiplos fatores independentes).

✗ Por que as outras estão erradas:

- *Accounting*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Federation*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Authorization*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

7) A — A Autenticação foi bem-sucedida, mas a Autorização foi negada pela política de privilégios.

✓ **Por que está certa:** O sistema reconheceu com sucesso quem é o usuário (Autenticação OK), mas verificou em sua lista de controle de acesso (ACL) que ele não possui permissão para aquele recurso (Autorização Negada).

✗ Por que as outras estão erradas:

- *O modelo AAA foi corrompido e o servidor caiu*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *A auditoria de Accounting bloqueou o usuário por inatividade*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *O usuário precisa trocar sua chave assimétrica*: Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

8) A — Atua como Autenticador (Network Access Server - NAS), intermediando os pacotes entre o cliente e o servidor RADIUS.

✓ **Por que está certa:** No modelo 802.1X/RADIUS, o Access Point é o Autenticador (NAS/Pass-through): ele não armazena as credenciais, apenas repassa as solicitações do suplicante (cliente) para o servidor de autenticação.

✗ **Por que as outras estão erradas:**

- *Atua como o próprio servidor de banco de dados de senhas:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Atua como autoridade certificadora raiz offline:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Desempenha apenas o papel de Accounting sem tocar na autenticação:* Cifra legada com tamanho de chave/bloco insuficiente e vulnerável a quebras práticas modernas (como Sweet32 e ataques de fluência).

9) A — Encaminhamento de logs em tempo real para um servidor SIEM externo centralizado com regras de retenção WORM.

✓ **Por que está certa:** O envio centralizado e imediato de logs para um SIEM externo (ou syslog seguro) impede que um intruso com acesso local à máquina atacada consiga apagar as evidências da invasão.

✗ **Por que as outras estão erradas:**

- *Armazenamento dos logs apenas na memória RAM volátil:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Exclusão automática de logs a cada 24 horas:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Desativação de logs em contas com privilégio de administrador:* Cifra legada com tamanho de chave/bloco insuficiente e vulnerável a quebras práticas modernas (como Sweet32 e ataques de fluência).

10) A — Provedor de Identidade (Identity Provider - IdP), responsável por autenticar o usuário e emitir o token de asserção.

✓ **Por que está certa:** Em federação SAML, o IdP (como ADFS ou Okta) é o responsável por autenticar o usuário e fornecer uma declaração assinada (assertion token) ao Service Provider.

✗ **Por que as outras estão erradas:**

- *Service Provider (SP), responsável apenas por hospedar o e-mail:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Servidor de proxy reverso sem função de segurança:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Firewall de aplicação web (WAF):* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

